Privacy Policy

Effective Date: January 1, 2026
Last Updated: January 1, 2026

1 Introduction

leoj.de ("we," "us," or "our") operates an invoice and payment management application (the "Service"). This Privacy Policy explains how we collect, use, disclose, and safeguard your personal data when you use our Service, in accordance with the EU General Data Protection Regulation (GDPR) and German data protection laws (Bundesdatenschutzgesetz - BDSG).

2 Controller Information

The data controller responsible for your personal data is:

leoj.de - Leopold Jofer
Heisenbergstraße 7
85748 Garching bei München
Germany

Email: mail@leoj.de

Data Protection Officer: mail@leoj.de (if applicable)

3 Legal Basis for Processing

We process your personal data based on the following legal grounds under Article 6(1) GDPR:

- **(a) Consent:** You have given explicit consent for specific processing purposes
- **(b) Contract:** Processing is necessary for the performance of our contract with you
- **(c) Legal Obligation:** Processing is required to comply with legal obligations (e.g., tax and accounting laws)
- **(f) Legitimate Interest:** Processing is necessary for our legitimate interests in operating and improving the Service

4 Data We Collect

4.1 Account Information

When you create an account, we collect:

- Name and contact details (email address, phone number)
- Company name and address
- Login credentials (email and encrypted password)
- Account preferences and settings

Legal Basis: Contract performance (Art. 6(1)(b) GDPR)

4.2 Customer and Invoice Data

To provide invoice and payment management services, we collect:

- Customer names, addresses, and contact information
- Invoice details (numbers, dates, line items, amounts, tax information)
- Payment transaction data (amounts, dates, payment methods, references)

- Notes and communications related to customers and invoices

Legal Basis: Contract performance (Art. 6(1)(b) GDPR), Legal obligation (Art. 6(1)(c) GDPR)

4.3 Technical and Usage Data

We automatically collect:

- IP addresses and browser information
- Device information and operating system
- Access times and pages visited
- Error logs and performance data
- Session data and cookies

Legal Basis: Legitimate interest (Art. 6(1)(f) GDPR) for security, troubleshooting, and service improvement

4.4 Communication Data

When you contact us, we collect:

- Email correspondence
- Support ticket content
- Feedback and survey responses

Legal Basis: Legitimate interest (Art. 6(1)(f) GDPR) for customer support

5 How We Use Your Data

We use your personal data to:

- **Provide the Service:** Create and manage your account, process invoices, match payments
- **Communicate with You:** Send service-related notifications, respond to inquiries, provide customer support
- **Improve the Service:** Analyze usage patterns, fix bugs, develop new features
- **Ensure Security:** Detect and prevent fraud, abuse, and security incidents
- **Comply with Legal Obligations:** Meet tax, accounting, and other regulatory requirements
- **AI-Powered Features:** Process data through the Claude API to provide intelligent invoice matching and data extraction features

6 Data Sharing and Disclosure

6.1 Third-Party Service Providers

We share your data with the following processors who help us operate the Service:

Vercel Inc. (Hosting Provider)

- Purpose: Application hosting and delivery
- Location: Global CDN with data centers worldwide
- Safeguards: Data Processing Agreement, Standard Contractual Clauses

Convex Inc. (Database Provider)

- Purpose: Data storage and database management
- Location: As specified in service agreement
- Safeguards: Data Processing Agreement, encryption at rest and in transit

Anthropic PBC (AI Provider)

- Purpose: AI-powered invoice processing and payment matching
- Location: United States

- Safeguards: Data Processing Agreement, Standard Contractual Clauses
- Note: We minimize personal data sent to the API and do not retain data beyond operational necessity

All processors are bound by Data Processing Agreements compliant with Article 28 GDPR.

6.2 Legal Requirements

We may disclose your data when required by law, such as:

- In response to valid legal requests from authorities
- To comply with tax audits and financial reporting obligations
- To protect our legal rights or prevent illegal activity

6.3 Business Transfers

In the event of a merger, acquisition, or sale of assets, your data may be transferred to the acquiring entity, subject to the same privacy protections.

7 International Data Transfers

Some of our service providers are located outside the European Economic Area (EEA), particularly Anthropic (United States). We ensure adequate protection through:

- Standard Contractual Clauses (SCCs) approved by the European Commission
- Data Processing Agreements with security and confidentiality obligations
- Regular assessments of data transfer safeguards

8 Data Retention

We retain your personal data according to our Data Retention Policy:

- **Customer and account data:** Duration of business relationship plus 3 years
- **Invoice and payment data:** Minimum 10 years from end of calendar year (mandatory under German law § 147 AO, § 257 HGB)
- **Communication records:** 3 years after last contact
- **Technical logs:** 90 days
- **API usage data:** 30 days maximum

For detailed retention periods, please refer to our complete Data Retention Policy.

9 Your Rights Under GDPR

You have the following rights regarding your personal data:

9.1 Right of Access (Art. 15 GDPR)

You can request a copy of the personal data we hold about you.

9.2 Right to Rectification (Art. 16 GDPR)

You can request correction of inaccurate or incomplete data.

9.3 Right to Erasure (Art. 17 GDPR)

You can request deletion of your data, subject to legal retention obligations. Invoice and payment data must be retained for 10 years under German law.

9.4 Right to Restriction of Processing (Art. 18 GDPR)

You can request that we limit how we use your data during mandatory retention periods.

9.5 Right to Data Portability (Art. 20 GDPR)
You can request your data in a structured, machine-readable format.

9.6 Right to Object (Art. 21 GDPR)
You can object to processing based on legitimate interests or for direct marketing purposes.

9.7 Right to Withdraw Consent (Art. 7(3) GDPR)
Where processing is based on consent, you can withdraw it at any time.

9.8 Right to Lodge a Complaint
You have the right to lodge a complaint with your supervisory authority:

Der Bundesbeauftragte für den Datenschutz und die Informationsfreiheit (BfDI)
Graurheindorfer Str. 153
53117 Bonn, Germany

Or your relevant State Data Protection Authority (Landesdatenschutzbehörde).

10 Exercising Your Rights
To exercise any of these rights, please contact us at:

Email: mail@leoj.de
Subject: Data Subject Rights Request

We will respond to your request within one month, or inform you if we need additional time (up to three months for complex requests).

11 Data Security
We implement appropriate technical and organizational measures to protect your data:

- **Encryption:** Data is encrypted in transit (TLS) and at rest
- **Access Controls:** Strict authentication and authorization mechanisms
- **Regular Backups:** Daily backups with 90-day retention
- **Security Monitoring:** Continuous monitoring for security incidents
- **Employee Training:** Regular data protection training for staff
- **Vendor Management:** Due diligence on all third-party processors

12 Cookies and Tracking
We use the following types of cookies:

- **Essential Cookies:** Required for authentication and basic functionality (cannot be disabled)
- **Performance Cookies:** Help us understand how you use the Service (can be disabled in settings)

You can manage cookie preferences through your browser settings. Disabling essential cookies may affect Service functionality.

13 Automated Decision-Making
We may use AI-powered features (via Claude API) to:
- Suggest invoice matches with incoming payments
- Extract data from invoice documents
- Provide recommendations for payment allocation

These are assistive features only. You retain full control over all final decisions regarding invoice processing and payments. No fully automated decisions with legal or similarly significant effects are made without human review.

14 Children's Privacy

Our Service is not intended for individuals under 16 years of age. We do not knowingly collect data from children. If you believe we have collected data from a child, please contact us immediately.

15 Changes to This Privacy Policy

We may update this Privacy Policy from time to time. Material changes will be communicated via:

- Email notification to your registered address
- Prominent notice within the Service
- Updated "Last Updated" date at the top of this policy

Continued use of the Service after changes constitutes acceptance of the updated policy.

16 Contact Us

For questions about this Privacy Policy or our data practices:

leoj.de - Leopold Jofer
Heisenbergstraße 7, 85748 Garching bei München
Germany

Email: mail@leoj.de
Data Protection Officer: mail@leoj.de (if applicable)

17 Additional Information for German Users

17.1 Rechtsgrundlagen (Legal Bases)

This policy complies with BDSG (Bundesdatenschutzgesetz) in addition to GDPR requirements.

17.2 Auftragsverarbeiter (Processors)

All our processors have signed AVV (Auftragsverarbeitungsverträge) as required under German law.

17.3 Betroffenenrechte (Data Subject Rights)

All rights described in Section 9 are available to you without charge for the first request. Subsequent manifestly unfounded or excessive requests may incur a reasonable administrative fee.

Document Version: 1.0
Approved by: Leopold Jofer
Next Review Date: January 1, 2027